

Platform Compliance Implementation Checklist

Engineering roadmap aligned to the customer legal-review package

WORKING IMPLEMENTATION DOCUMENT

Updated September 12, 2026

Status: implementation in progress

Last updated: September 12, 2026

This checklist tracks engineering work needed to align the Pin2Win platform with the legal-review draft in `Pin2Win_Customer_Terms_and_Challenge_Rules_Draft.md`. It is not a substitute for approval by qualified Texas counsel or a CPA.

Status key: [x] complete, [~] in progress, [] not started, [!] blocked by owner or professional input.

1. Legal Documents and Acceptance

- ☐ OK Add permanent HTML routes for Terms of Use, Official Rules, Refund Policy, and Privacy Policy.
- ☐ OK Replace placeholder footer links with working internal links.
- ☐ OK Establish a single current legal-document version in application code.
- ☐ OK Display the effective date and business mailing address on every applicable document.
- ☐ ! Obtain Texas counsel approval before changing the documents from legal-review draft to effective customer terms.
- ☐ OK Add an unchecked pre-checkout acceptance control with links to all four documents.
- ☐ OK Require separate age-18, Texas-residency, and onsite-presence attestations.
- ☐ OK Record user, challenge, checkout, document versions, acceptance text, UTC timestamp, IP address, user agent, location, and bay.
- ☐ OK Reject checkout server-side when current-version acceptance is absent or incomplete.
- ☐ OK Preserve an immutable copy or cryptographic hash of each accepted document version.

2. Challenge Configuration and Sale Controls

- ☐ Move all material challenge details into enforceable database configuration.
- ☐ Store status, start/end time, entry fee, prize amount, shot count, attempt window, course, hole, tee, pin, target distance, simulator settings, and rules version.
- ☐ Associate each challenge with explicitly authorized active Texas locations and bays.
- ☐ Reject checkout when the challenge is draft, paused, closed, completed, outside its sale period, or incompletely configured.
- ☐ Validate location and bay server-side instead of trusting QR query parameters.
- ☐ Display every material challenge detail immediately before payment.
- ☐ Remove or replace expired hard-coded fallback dates and test event codes.

3. Hole-in-One Result and Winner Controls

- ☒ OK Replace closest-to-the-pin scoring behavior in the Hole-in-One Challenge.
- ☒ OK Record whether an eligible shot is an actual hole-in-one.
- ☒ OK Record simulator shot/session IDs and the exact source timestamp.
- ☒ OK Preserve original evidence, source metadata, and verification history.
- ☒ OK Require an authorized verifier and verification timestamp.
- ☒ OK Select the earliest valid hole-in-one by simulator timestamp.
- ☒ OK Use a transaction or lock so concurrent verifications cannot create multiple winners.
- ☒ OK Implement the equal-split fallback when chronology cannot reliably be determined.
- ☒ OK Automatically pause sales when a potential hole-in-one is reported.
- ☒ OK Close the challenge after the winning result is approved.
- ☒ OK Identify paid entries that cannot be used because the challenge closed and provide an administrator-confirmed, idempotent Square refund action.

4. Winner Claim and Prize Administration

- ☐ Create a potential-winner claim record and secure administrator workflow.
- ☐ Track notice date, ten-day response deadline, eligibility review, acceptance/refusal, disqualification, and successor status.
- ☐ Provide secure identity, Texas-residency, affidavit, and W-9 collection.
- ☐ Prohibit tax identifiers and identity documents from ordinary email workflows.
- ☐ Track payout approval, payment date, amount, method, and 30-day target.
- ☐ Track Form 1099-MISC preparation and delivery.
- ☐ ! Have a CPA confirm W-9, 1099-MISC, and backup-withholding procedures.
- ☐ ! Confirm that the full advertised prize is reserved or insured before sales open.

5. Refund and Payment-Issue Handling

- ☐ Add a customer payment/refund claim page and authenticated API.
- ☐ Capture claim reason, entry/payment identifiers, venue, date/time, narrative, and evidence.
- ☐ Enforce or flag the 14-calendar-day submission period while preserving legally required exceptions.
- ☐ Add claim statuses, assignments, notes, customer communications, and decision history.
- ☒ Add Square refund execution and store the provider refund ID.
- ☒ Add REFUND_PENDING, PARTIALLY_REFUNDED, and REFUNDED states where applicable.
- ☒ Update checkout and entry records together when a refund is approved.
- ☐ Automatically identify successful payments with no usable entry.
- ☐ Notify administrators and customers of reconciliation failures.
- ☒ Preserve an append-only refund audit trail.

6. Payment Reliability and Reconciliation

- ☒ OK Verify Square webhook signatures in production.
- ☒ OK Verify order ID, amount, currency, and completed-payment state.
- ☒ OK Use idempotent entry creation for Square completion and webhook races.
- ☒ OK Record checkout, payment, entry, access, and email audit events.
- ☐ Add a scheduled reconciliation job for paid-without-entry and entry-without-payment cases.
- ☐ Retry recoverable webhook and confirmation-email failures.
- ☐ Add administrator alerts and a reconciliation queue.
- ☐ Prevent simulator-code access when eligibility or acceptance later proves invalid.

7. Privacy Operations

- ☐ Add a privacy request and appeal mechanism.
- ☐ Support access, correction, deletion, portable copy, opt-out, and appeal request types.
- ☐ Add request identity verification, deadlines, decisions, and response records.
- ☐ Build administrator tools for export, correction, deletion/anonymization, and appeal review.
- ☐ Adopt and encode a data-retention schedule by record type.
- ☐ Maintain a current service-provider/vendor inventory.
- ☐ Restrict and audit access to identity, evidence, and tax documents.
- ☐ Document deletion exceptions for accounting, fraud prevention, disputes, and legal obligations.

8. Security and Administration

- ☒ OK Use one-hour rolling player sessions with server-side expiration.
- ☒ OK Use secure, HTTP-only production session cookies.
- ☒ OK Hash player passwords with a per-password salt.
- ☐ Add rate limiting to authentication, recovery, checkout, and claim endpoints.
- ☐ Add multi-factor authentication for administrators.
- ☐ Replace shared administrator credentials with individual administrator accounts and roles.
- ☐ Add origin/CSRF enforcement to sensitive same-site mutations.
- ☐ Add production security headers and a Content Security Policy.
- ☐ Validate evidence uploads by type and size and add malware controls.
- ☐ Encrypt or isolate sensitive winner documents with least-privilege access.
- ☐ Add database backup, restore testing, secret rotation, and incident-response procedures.
- ☐ Replace destructive entry deletion with auditable archival.

9. Communications, Testing, and Launch

- ☐ Include exact challenge details and accepted-document versions in the payment confirmation record.
- ☐ Link current rules and refund support from payment and entry communications.
- ☐ Test consent requirements on account creation, login, and already-signed-in QR flows.
- ☐ Test challenge state and time boundaries in the browser and directly against the API.
- ☐ Test concurrent potential-winner verification and challenge closure.
- ☐ Test automatic refunds for unused entries after challenge closure.
- ☐ Test privacy and refund request deadlines and audit histories.
- ☐ Test Square webhook retries, duplicates, delayed delivery, and reconciliation.
- ☐ Complete accessibility and mobile checkout review.
- ☒ OK Insert the approved effective date and business mailing address.
- ☐ ! Obtain final Texas counsel and CPA approval.
- ☐ Remove draft banners and internal launch material only after approval.
- ☐ Complete a production launch rehearsal before enabling paid entries.

Owner/Professional Inputs Still Required

- Texas attorney approval and any required structural changes.
- CPA-approved tax collection, withholding, reporting, and payout procedure.
- Confirmation that the \$5,000 prize is reserved or insured.
- Final challenge course, hole, tee, pin, target distance, simulator configuration, sale period, and participating locations.